

HOW CAN WE UPGRADE DEFENSES:

For each defense, there should be plausible upgrades relating to how defenses are utilized for defending against an attack. For each defense we can potentially do the following upgrades, both brainstormed by me and our AI counterparts. No tool can be 100% effective against an attack as people always find a way.

ATM Inspections:

- Level 1: Simple checks for skimmers or hidden cameras: - defends against ATM Skimming and tampering.
- Level 2: Perform software updates on ATMs – protects against malware
- Level 3: Tamper proof seals – defends against ATM Skimming
- Since humans are not perfect, only 40% of checks are effective for level 1, software updates take it to 75% and then 95% for tamper proof seals.

Background Checks:

- Level 1: Screening Finance Department Hires – defends against Insider Fraud
- Level 2: Vetting contractors with system access – defends against Insider Fraud
- Level 3: Continuous Monitoring (reviewing access logs periodically) – defends against Insider Fraud.
- Most insider fraud is within the company not contractors so lets call it 60% maybe will be protected by level 1 and 85% by level 2 and level 3 could bring total effectiveness to 95%.

DDoS Protection:

- Level 1: Protecting online bank portals – defends against DDoS
- Level 2: Shielding e-commerce sites – defends against DDoS
- Level 3: Safeguarding government services portals – defends against DDoS
- For DDoS, let's say 100% of DDoS attacks are against the sites above, so protecting against banks could be 60% effective, e-commerce sites takes it to 90% and then 99% for government service portals. *

Deepfake Detection Software:

- Level 1: Screening video based job interviews – defends against Deepfake fraud
- Level 2: Detecting fake audio commands in customer services – defends against Vishing & Deepfake fraud
- Level 1 at 70% effectiveness (good but not perfect), level 2 at 90% effectiveness and then can be stacked with other defenses like MFA to hit 99%.

Email Filtering:

- Level 1: Blocking phishing attempts with malicious links – defends against Phishing
- Level 2: Filtering spam invoices with suspicious attachments – defends against Phishing
- Level 3: Auto-quarantining spoofed domains. Protocols like DMARC are very effective. – defends against Business Email Compromise
- Level 1 can be 80%, catches the obvious stuff, level 2 at 90% effectiveness and then level 3 at 99%.

HTTPS and Encryption:

- More binary, if implemented it is highly effective, not really room for upgrades
- Without HTTPS you are 95% vulnerable to attacks.

Input Validation and Sanitisation:

- Level 1: Preventing SQL Injection on login forms – defends against SQL Injection
- Level 2: Blocking script injections in search fields – defends against XSS + SQL Injection
- Level 3: Web Application Firewall - defends against SQL Injection, XSS.
- Level 1 could be 85% effective, level 2 could be 95% effective against SQLi and XSS and level 3 could be 99%.

Keep Software Updated:

- Level 1: Updating payment processing software (only 1 part of the system) – defends against Ransomware
- Level 2: Applying OS Security patches (much broader protection) – defends against Ransomware
- Level 3: Rolling out browser updates against exploits (Comprehensive coverage) – defends against Ransomware
- Level 1 could be 70% effective, level 2 maybe at 90% and level 3 at 95%

MFA:

- Level 1: Online banking logins – defends against Account Takeover + Brute-force + Phishing.
- Level 2: Cloud service sign-ins with app-based authentication – Account Takeover + Brute-Force + Phishing + Sim Swap Fraud
- Level 3: App based authentication with biometric/hardware key – All of the above just better
- Level 1 at 80% (vulnerable to sim swap), level 2 at 95%, level 3 at 99%.

Network Monitoring:

- Level 1: Detecting unusual outbound traffic – defends against Cryptojacking + DDoS
- Level 2: Spotting brute-force login attempts – defends against Brute-force
- Level 3: AI driven anomaly detection – defends against Insider Fraud
- Level 1: 70% effective, catches large anomalies, level 2 at 90%, level 3 at 95%.

Principle of Least Privilege:

- Level 1: Interns only get read-only access to databases – defends against Insider Fraud
- Level 2: Finance staff can't alter payroll code – defends against Accounting and Invoice Fraud
- Level 3: Admin rights restricted to IT team – defends against Account takeover
- Level 1 at 65% effectiveness, reduces risk significantly, level 2 at 90%, level 3 at 99%

Regular Audits:

- Level 1: Reviewing employee expense claims – defends against Accounting and Invoice Fraud
- Level 2: Checking system access logs – defends against Insider Fraud
- Level 3: Validating vendor invoices – defends against Business Email Compromise
- Level 1 at 60%, deters casual fraud, level 2 at 85%, catches unauthorized activity and level 3 at 95%, very strong against BEC.

Regular Password Changes:

- Level 1: Enforcing 90-day password reset – defends against Account Takeover
- Level 2: Enforcing passwords of a minimum of 14 characters – defends against Brute Force
- Level 3: Passwordless authentication with biometrics – defends against Synthetic Identity Theft
- Level 1 at 40%, level 2 at 80% and level 3 at 99%.

Regulated Automated Backups:

- Level 1: Weekly backup of financial ledgers – defends against Ransomware
- Level 2: Immutable backups with air-gapped storage – defends against Ransomware + Insider Fraud.
- Level 1, most of the data is recovered, but recovery process may have costs and they lose a days worth of transactions (60% effective maybe), level 2 is 99% effective, seen as the gold standard.

Segregation of Duties:

- Level 1: Separate software developers from production deployment - defends against Insider Fraud
- Level 2: One employee approves payments, another executes payments - defends against Accounting and Invoice Fraud
- Level 3: Multi-person authorization for critical system changes - defends against Business Email Compromise.
- Level 1 at 90%, very strong control. Level 2 at 95% maybe, very effective, level 3 at 99% - nearly perfect.

Traffic Filtering:

- Level 1: Blocking known malicious IP ranges – defends against DdoS and brute force
- Level 2: Filtering bot traffic from APIs with rate limiting – defends against Brute-force
- Level 1 at 40% for DdoS and 80% for brute-force. Level 2 at 95% vs brute force and 60% vs DdoS.

User Education:

- Level 1: Phishing and Vishing awareness training – defends against Phishing and Vishing
- Level 2: Social engineering scam simulations – defends against Investment Scams
- Level 3: Continuous micro training. Short frequent lessons
- Level 1 at 50%, some people always click. Level 2 at 75%, practical training works better and then level 3 at 85% effectiveness.

Verification Protocols

- Level 1: Two-step approval for wire transfers – defends against Authorized push payments
- Level 2: Caller identity verification in customer support – defends against Vishing
- Level 3: Biometric verification for high-value transactions – defends against SIM Swap Fraud
- Level 1 is very strong already – 90% effective, level 2 at 95% and level 3 at 99%

VPN Usage:

- Another binary control, without VPN on public wifi you are 90% vulnerable to MITM attacks and with VPN you are 99% protected.

Application Sandboxing:

- Level 1: Isolating untrusted applications from system resources – defends against Ransomware
- Level 2: Containing web browser processes to prevent exploit spread – Zero-Day Exploits
- Full system virtualization – running high risk tasks in a completely virtual machine – defends against Zero day exploits.
- Level 1 is 85% effective, level 2 at 95% effective, level 3 at 99%